DiffAudit 团队入门扫盲文档

给第一次接触“扩散模型隐私审计”方向的组员看的入门材料

这份文档的目的：帮团队先建立共同认知，知道这个领域是什么、我们要做什么、第一步该怎么做。

适合谁看：对扩散模型、隐私攻击、成员推断几乎不了解的同学。

整理依据：团队现有 PRD 与前期文献整理材料

1. 先用一句话说清楚：我们到底在做什么

一句话定位

我们不是在做“让 AI 画图更好”的项目，

我们是在做“给扩散模型做隐私体检”的项目。

更具体地说，我们想检查一个扩散模型有没有把训练数据记得太死。所谓“记得太死”，就是模型本来应该学会一类图片的规律，但实际上却对某些具体样本特别熟，熟到别人可以据此判断它是否见过这些样本，甚至进一步担心它会泄露训练信息。

所以，DiffAudit 的核心目标不是单纯做一个攻击算法，而是做一个“隐私风险审计原型系统”：能够检测风险、展示证据、解释原因，并在必要时给出修复建议。

2. 这个领域研究的核心问题是什么

这个方向的核心问题只有一个：扩散模型会不会“背题”。

如果把训练集想象成一本题库，那么理想中的模型应该学会“出题规律”，而不是把某些题和答案直接背下来。但现实中，模型可能会对部分训练样本产生异常熟悉的反应，这就带来了隐私风险。

这个领域通常在研究三件事

- 模型有没有记住训练样本，也就是“记忆”问题；
- 我们能不能判断一张图是不是训练集成员，也就是“成员推断”问题；
- 如果存在风险，我们能不能把风险量化、可视化，并整理成报告，也就是“审计系统”问题。

我们团队做的 DiffAudit，本质上是把这三件事串起来：先理解模型为什么会暴露成员性，再用技术手段把它检测出来，最后把结果整理成非技术人员也能看懂的形式。

3. 扩散模型到底是什么

扩散模型可以先用最朴素的方式理解：它是一个“学会去噪”的模型。

- 训练时，先把真实图片一点点加噪，最后变得很乱；
- 模型学习：如果我看到某一步的带噪图片，应该怎么把它变得更干净一点；
- 生成时，再从纯噪声开始，一步一步去噪，最后得到一张图。

所以，扩散模型最重要的直觉就是：它能把“噪声”一步步变成“图像”。Stable Diffusion 就属于这条技术路线，只不过它很多计算不是直接在原始像素图上做，而是在压缩后的“潜空间”里做，这样更省算力。

4. 团队必须统一的基础术语

术语	人话解释	为什么重要
成员推断（MIA）	给模型一张图，猜它训练时见没见过。	这是项目最核心的攻击/审计问题。
记忆（memorization）	模型是不是把某些训练样本记得过深。	它和成员推断相关，但不完全等价。
白盒	能看到模型内部很多信息，比如参数、中间过程。	通常最强，也最适合做项目主线。
黑盒	只能输入和看输出，碰不到模型内部。	最贴近真实 API 场景。
灰盒	能看到一部分内部信息，但不是全部。	适合做解释增强，比如注意力图。
DDIM 反演	把一张图倒着推回它对应的噪声。	白盒主线常用技术。
重建误差	原图和模型重建图差了多少。	常用来区分成员和非成员。
潜空间（latent space）	模型内部的压缩表示空间。	Stable Diffusion 等模型常在这里操作。
Attention 热力图	模型在生成时更关注哪里。	可以作为“为什么有风险”的证据。

5. 这个领域的人通常是怎么“攻击”模型的

这里的“攻击”，不是把系统打崩，而是利用模型对成员样本和非成员样本反应不同这一点，去判断一张图是否进过训练集。

常见的几条思路

- 看 loss / likelihood：如果模型对一张图特别“顺手”，它可能更像训练成员；
- 看扩散过程中的逐步误差：成员样本在多个时间步上可能都更稳定；
- 做反演和重建：先把图倒回噪声，再重建回来，看模型能不能重建得特别好；

• 利用更强的白盒信息：比如梯度、中间特征、注意力等。

为什么白盒最适合做第一阶段主线

因为白盒能看到的信息最多，更容易做出清晰的实验结果。

对我们团队来说，它也最容易做出“原图 - 重建图 - 误差值”这种能展示、能解释的证据链。

6. 防御方法大致分哪几类

我们之前整理的文献主要集中在防御侧，这很好，因为它说明团队已经知道这个领域不是只有“怎么攻击”，还包括“怎么减轻风险”。下面把它们用更容易懂的方式重组一下。

防御阶段	核心想法	我们可以怎么理解
训练阶段	训练时就尽量别让模型记得太死。	典型代表是差分隐私；优点是理论硬，缺点是常常牺牲生成质量。
微调阶段	模型已经有了，在微调时降低成员风险。	适合 LoRA 等现实场景。
数据拆分 / 蒸馏	别把记忆集中压在一个模型里。	更像从数据和模型结构上分散风险。
推理阶段	不改模型，直接在推理前或推理时降低可区分性。	部署成本低，适合以后做成“防御建议模块”。
主体级防御	重点保护某类人、某个主体不被模型学会。	提醒大家：隐私问题不只是一张图是不是成员。

7. DiffAudit 最终想做成什么样

这部分一定要全员统一。我们最后做的，不应该是一堆零散脚本，也不应该只是论文复现，而应该是一个“扩散模型隐私风险审计原型系统”。

它至少包含四层

• 模型层：能加载一个扩散模型；

• 审计层：能做白盒、灰盒、黑盒三类风险检测；

• 证据层：能展示原图、重建图、误差、热力图、风险分数；

• 报告层：能把结果整理成更容易读懂的结论和建议。

一句更适合对外介绍的话

DiffAudit 是一个面向扩散模型的隐私风险检测与审计原型系统。

它的目标不是只给一个分数，而是尽量回答“风险有多大、依据是什么、为什么这样判断、接下来怎么办”。

8. 第一版到底做什么：先打穿一个最小闭环

项目刚启动时，最容易犯的错误就是：一上来想把白盒、灰盒、黑盒、UI、报告、所有模型兼容都做完。这样最后往往什么都没做扎实。

正确做法是：先打穿一个最小闭环。对你们来说，最合适的闭环就是白盒主线。

第一版最小闭环

• 选一个模型，先不要贪多；

• 准备一组成员图和一组非成员图；

• 对每张图做 DDIM 反演和重建；

• 计算重建误差；

• 看成员组和非成员组能不能拉开差距；

• 把结果做成可视化页面或报告截图。

只要这六步能跑通，我们的项目就已经“活了”。后面再逐步补黑盒、灰盒和防御建议，就会顺得多。

9. 团队里不同角色，现在分别该学什么

角色	先弄懂什么	近期能产出什么
算法同学	扩散模型基础、MIA、白盒/黑盒/灰盒、DDIM 反演、重建误差。	复现主线实验，跑出误差和分布图。
工程同学	模型加载、图像输入输出、重建流程、结果保存、简单前端展示。	做原型界面或脚本流程。
文案 / 申报同学	项目背景、研究问题、创新点、为什么做成“审计系统”。	申报书、汇报稿、PPT 提纲。

10. 全员现在必须记住的 10 句话

1. 我们做的是扩散模型隐私审计，不是普通图像生成。

2. 扩散模型本质上是在学“从噪声一步步变成图像”。

3. Stable Diffusion 这类模型很多操作发生在潜空间里。

4. 模型可能会记住训练样本，这会带来隐私风险。

5. 成员推断是在猜一张图是不是训练集成员。

6. 白盒、灰盒、黑盒，是按我们能看到模型多少信息来分的。

7. 对我们现在来说，白盒最适合作为第一阶段主线。

8. 白盒主线最关键的两个词是：DDIM 反演、重建误差。

9. 我们最终要做的是“能检测、能解释、能展示、能出报告”的原型系统。

10. 第一版先打穿一个最小闭环，再逐步扩展。

最后一句最通俗的话

可以把 DiffAudit 理解成“给扩散模型做隐私体检”的系统。

我们要做的，是检查它有没有记住不该记住的东西，并把风险讲清楚。